

Termin 5 – Resilienz als Organisationsfähigkeit

Prof. Dr. Dirk Loomans

29. September 2026

Vorlesungsskript • Grundlagen der Resilienz • Cyber Security Management (B.Sc.), 1. Semester • Hochschule Mainz

Vorbemerkung: Dieses Skript dient als Vorlesungsbegleitung und erhebt keinen akademischen Anspruch. Dennoch kann es bei der Klausurvorbereitung hilfreich sein. Kommentare und Verbesserungsvorschläge gerne an den Autor über dirk.loomans@hs-mainz.de.

Leitfrage

Wie überlebt die Organisation – und bleibt dabei handlungsfähig?

Technik schafft Potenzial – Organisation aktiviert es. Im Ernstfall entscheidet nicht Technologie, sondern Verhalten.

Lernziele

Nach diesem Termin können Studierende

- erklären, was organisationale Resilienz nach ISO 22316 ist,
- erkennen, welche Rollen, Prozesse und Kommunikationsmuster Resilienz fördern oder behindern,
- beschreiben, wie Training, Governance und Lernkultur Widerstandsfähigkeit institutionalisieren.

Fachinhalte

Von der technischen zur organisationalen Resilienz

Technische Resilienz sichert Systeme, organisationale Resilienz sichert Entscheidungen. Organisationale Resilienz ist die Fähigkeit, das technische Potenzial unter Stress, Zeitdruck und Informationsunsicherheit gezielt zu aktivieren: Wer erkennt den Vorfall? Wer informiert wen? Wer entscheidet, was in welcher Reihenfolge getan wird?

Aspekt	Technische Resilienz	Organisationale Resilienz
Steuerungslogik	deterministisch, automatisiert	adaptiv, situativ
Fokus	Systeme und Prozesse	Menschen, Rollen, Kommunikation
Nachweis	Monitoring, Failover-Tests	Übungen, Entscheidungswege, Lernfähigkeit
Zielgröße	System bleibt funktionsfähig	Organisation bleibt handlungsfähig

Leitfäden zum Incident Handling (NIST SP 800-61, ENISA) betonen, dass die Wirksamkeit maßgeblich von klaren Zuständigkeiten, Kommunikationswegen und geübten Prozessen abhängt [1]. Organisationale Resilienz wirkt wie ein „soziales Redundanzsystem“.

Definition nach ISO 22316

„Die Fähigkeit einer Organisation, Störungen vorherzusehen, sich vorzubereiten, zu reagieren und sich anzupassen, um in einem sich verändernden Umfeld zu überleben und zu gedeihen.“ [2]

Kernkomponenten:

- **Strukturen** → klare Rollen und Verantwortlichkeiten
- **Prozesse** → Detection, Reaktion, Wiederanlauf
- **Menschen** → Ausbildung, Training, Entscheidungsfähigkeit
- **Kultur** → Fehleroffenheit und Lernfähigkeit

Resilienz wird damit zu einer Verhaltensdisziplin: Sie entsteht nicht in der Dokumentation, sondern in der Übung.

Der Resilienzyklus



Abbildung 1: Resilienzyklus: Detection, Response, Recovery, Adapt

- **Detection** – Wahrnehmungsfähigkeit: technische Sensorik (SIEM, Anomalieerkennung) und organisatorische Meldekultur. Ziel ist zielgerichtete Wahrnehmung, nicht absolute Überwachung.
- **Response** – koordinierte Reaktion unter Unsicherheit. Ein Incident darf nicht an individuellen Grenzen hängen bleiben; alle handeln entlang einer gemeinsamen Lageeinschätzung.
- **Recovery** – Wiederherstellung der Handlungsfähigkeit, priorisiert nach Business Impact, mit gesicherter Stakeholder-Kommunikation und Blick auf die Belastung des Teams.
- **Adapt** – Lernen über After-Action Reviews und Post-Mortems. Eine Organisation, die nach jedem Vorfall besser wird, ist per Definition resilient.

Während PDCA auf Qualitätsmanagement zielt, fokussiert der Resilienzyklus reaktive und adaptive Fähigkeiten im Krisenfall.

Rollen und Entscheidungslogik

Effektive Krisenorganisationen definieren **Rollen statt Personen**. Das verhindert Abhängigkeit von Einzelnen und skaliert in 24/7-Betrieben.

Rolle	Hauptverantwortung
CISO	Strategische Leitung, Entscheidung über Eskalationsstufen, Kommunikation mit der Geschäftsleitung
Incident Commander	Operative Gesamtkoordination im Ereignisfall, Priorisierung
IT Operations / Technical Lead	Analyse, technische Eindämmung und Wiederherstellung
BCM-Manager	Koordination mit Fachbereichen, Priorisierung kritischer Prozesse
Kommunikation / PR	Interne und externe Information
Legal / Datenschutz	Bewertung von Meldepflichten (z. B. Art. 33 DSGVO)
Management Board	Ressourcenfreigabe, Business-Priorisierung, Risikoakzeptanz

Kernprinzip: **Wer entscheidet was, wann und warum?** Der normale Linienweg ist in Krisen zu langsam. Das Incident Command System aus dem Katastrophenschutz liefert Entscheidungskompetenz auf Zeit: Command priorisiert, Operations handelt, Support dokumentiert und kommuniziert. Prinzipien wirksamer Führungsstrukturen: Unity of Command, Span of Control (5–7 Personen), Delegation of Authority, Documentation & Traceability, Role Rotation & Training.

Unter Stress greifen Menschen auf erlernte Muster zurück. Playbooks, Priorisierungslisten und Entscheidungsbäume bereiten Entscheidungen vor.

Kommunikation unter Stress

Krisenkommunikation ist Teil der Resilienzarchitektur. Viele Vorfallsbehandlungen scheitern an Informationsfehlern, nicht an Technik. Leitprinzipien (CCCC):

1. **Clear** – eindeutig, frei von Mehrdeutigkeit
2. **Concise** – kurz statt detailüberladen
3. **Confirmed** – der Empfänger bestätigt („Readback,,“)
4. **Coordinated** – alle sprechen auf Basis derselben Lage

„Eine Info ist nur so gut wie ihre Bestätigung.“ Kommunikationskanäle müssen vorher definiert und getestet sein.

Exkurs: Vier Seiten einer Nachricht

Nach Schulz von Thun hat jede Botschaft vier Ebenen [3]: Sachinhalt, Selbstoffenbarung, Beziehung, Appell. Beispiel im Incident: „Der Server ist schon wieder down.“

Ebene	Botschaft
Sachinhalt	Der Server ist nicht erreichbar.
Selbstoffenbarung	Ich bin genervt und gestresst.
Beziehung	Ihr hättet das früher merken müssen.
Appell	Bitte tut endlich etwas!

In Stresssituationen hören Menschen häufig auf der falschen Ebene. „Resilienz in Kommunikation heißt: auf allen vier Ohren bewusst sprechen und hören.“

Incident-Response-Prozess

Standardphasen laut Unterlagen (nach ISO/IEC 27035):

1. Detection & Reporting – Ereignis erkennen und melden
2. Triage & Classification – Kritikalität bestimmen
3. Containment – Ausbreitung stoppen
4. Eradication – Ursache beseitigen
5. Recovery – Systeme wiederherstellen
6. Lessons Learned – Erkenntnisse in Prozesse zurückführen

Jede Phase braucht definierte Owner, Playbooks und Kommunikationskanäle. Zur Phasengliederung der Norm siehe [Hinweise zur Aktualität](#).

Übungs- und Trainingskultur

Resilienz ist keine Theorie – sie entsteht durch Übung.

- **Tabletop-Übungen:** szenariobasierte Planspiele zu Kommunikation und Entscheidungswegen, ohne technischen Aufwand.
- **Live-Simulationen:** technische Reaktionsfähigkeit unter Realbedingungen (Red Team, „Ransomware-Day“, Provider-Ausfall).
- **After-Action Reviews:** strukturiertes Feedback, keine Schuldzuweisung.

Metrik	Aussage
Time to Detect (TTD)	Wie schnell wird ein Incident erkannt?
Time to Decision	Wie schnell fällt eine handlungsleitende Entscheidung?
Time to Recover (TTR)	Wann sind kritische Systeme wieder lauffähig?
Communication Efficiency	Verhältnis bestätigter zu gesendeten Meldungen
Exercise Frequency	Anzahl der Übungen pro Jahr

Verankerung: mindestens zwei Tabletop-Übungen pro Jahr, strukturierte Lessons-Learned-Protokolle, Teilnahme des Managements, standardisierte Bewertung. Ein Team, das regelmäßig übt, erlebt weniger Panik im Ernstfall.

Resilienz-Governance

Managementsystem	Bezug zur Resilienz
ISMS (ISO/IEC 27001)	Struktur für Informationssicherheit und Incident Management
BCMS (ISO 22301)	Kontinuität kritischer Geschäftsprozesse
Risk Management (ISO 31000)	Identifikation und Bewertung von Bedrohungen
Crisis Management (ISO 22320)	Entscheidungs- und Kommunikationsstrukturen im Ereignisfall
Resilience Management (ISO 22316)	verbindet die Systeme zu einer adaptiven Gesamtstruktur

Governance-Prinzipien: Verantwortung, Transparenz, Partizipation, Kontinuität, Lernfähigkeit. Kennzahlen: RTO-Erreichung, Übungshäufigkeit, Umsetzungsgrad der Lessons Learned, Reaktionszeit von Managemententscheidungen, Kommunikationslatenz. Nachweise: Übungs- und Incident-Protokolle, Nachverfolgung von Lessons Learned, Management Reviews, Schulungsnachweise. Berichtspflicht an Management und Aufsicht.

„Resilienz ist keine Projektaufgabe, sondern Führungsverhalten.“

Kultur und Lernen

- **Blame-free Post-Mortems:** Statt „Who caused it?“, lautet die Frage „What can we improve?“ Leitfragen: Was ist passiert? Warum? Wie haben wir reagiert? Was lernen wir und wie setzen wir es um?
- **Psychologische Sicherheit** [4]: Teams dürfen Fehler zugeben und Unsicherheiten melden, ohne Angst vor persönlichen Konsequenzen.
- **Transparente Kommunikation:** Fehler werden geteilt, nicht versteckt.
- **Institutionelles Lernen:** Lessons Learned fließen in Prozesse; Organisationen entwickeln sich zur lernenden Organisation [5].

„Technik stabilisiert Systeme – Organisation stabilisiert Verhalten – Kultur stabilisiert Vertrauen.“

Übungen

Kommunikationsübung: Vier Seiten einer Nachricht

3er-Gruppen, 10 Minuten. Analysieren Sie die Aussage aus einer Incident-Situation: „**Warum habt ihr das Backup noch nicht eingespielt?**“,

- Welche Botschaften stecken in den vier Ebenen?
- Wie könnte dieselbe Aussage resilienter formuliert werden?
- Welche Missverständnisse entstehen, wenn nur eine Ebene gehört wird?
- Welche Kommunikationsregeln helfen, in Stresslagen klar zu bleiben?

Gruppenübung: Ransomware am Montagmorgen

Montag, 08:15 Uhr: Mitarbeitende melden, dass Dateien auf Netzlaufwerken nicht mehr geöffnet werden können. Mehrere File-Server sind verschlüsselt, eine Lösegeldforderung erscheint. Cloud-Sync ist betroffen, VPN und Mail laufen noch.

Gruppen, 15–20 Minuten:

1. Wer übernimmt die Incident-Leitung?
2. Welche Systeme oder Personen müssen sofort informiert werden?

3. Welche Entscheidungen sind in den ersten 30 Minuten kritisch?
4. Wie läuft die interne und externe Kommunikation?
5. Welche Priorität hat Recovery gegenüber Forensik?
6. Wann erfolgt die Meldung an Aufsichtsbehörden (DSGVO Art. 33 / NIS-2)?

Typischer Verlauf und häufige Fehler zur Reflexion im Plenum:

Phase	Beschreibung	Häufige Fehler
Detection	erste Hinweise, z. B. unzugängliche Daten	Unterschätzung der Lage, verspätete Eskalation
Response	Eindämmung, z. B. Netzwerksegmentierung	fehlende Koordination, doppelte Maßnahmen
Communication	interne und externe Information	Intransparenz, widersprüchliche Aussagen
Recovery	Wiederherstellung aus Backups	keine Priorisierung, ungetestete Backups
Adapt	Ursachenanalyse, Lessons Learned	keine systematische Nachbereitung

Typische Lessons Learned: Playbooks sind Gold wert, wenn sie aktuell und trainiert sind. Ein Backup ist nur so gut wie der letzte Restore. Kommunikation entscheidet über Vertrauen. Forensik und Wiederanlauf müssen abgestimmt sein. Reviews sind Lerngelegenheiten.

Prüfungsrelevante Leitfragen

- Was versteht ISO 22316 unter organisationaler Resilienz, und welche Kernkomponenten gehören dazu?
- Beschreiben Sie die vier Phasen des Resilienzyklus und ihre organisatorische Umsetzung.
- Warum scheitern viele Cyber-Resilienzmaßnahmen nicht an Technik, sondern an Organisation?
- Welche Rolle spielt Kommunikation in Krisen- und Notfallsituationen? Erläutern Sie die CCCC-Prinzipien.
- Wenden Sie das Modell von Schulz von Thun auf eine Aussage aus einem Incident an.
- Welche Formen von Resilienztraining gibt es, und welche Kennzahlen machen ihren Erfolg sichtbar?
- Wie wird Resilienz in bestehende Managementsysteme integriert?

Merksätze: Organisationale Resilienz ist die Fähigkeit zur koordinierten Reaktion. Rollen, Kommunikation und Übung sind entscheidend. Recovery muss technisch und organisatorisch funktionieren. Lernen ist Teil des Zyklus, nicht dessen Nachbereitung.

Vor- und Nachbereitung

Ausblick Termin 6: Rollen und Verantwortlichkeiten in der Cyber-Organisation – CISO, SOC, CERT und weitere Schlüsselrollen.

Material aus dem Archiv

05 Resilienz als Organisationsfähigkeit/05_Resilienz als Organisationsfähigkeit.pdf und Skript Sitzung 5 Resiliente Organisationsentwicklung.pdf.

Bibliografie

- [1] P. Cichonski, T. Millar, T. Grance, und K. Scarfone, „Computer Security Incident Handling Guide“, NIST Special Publication 800-61 Rev. 2, Aug. 2012. doi: [10.6028/NIST.SP.800-61r2](https://doi.org/10.6028/NIST.SP.800-61r2).
- [2] „ISO 22316:2017 Security and resilience – Organizational resilience – Principles and attributes“. 2017.
- [3] F. Schulz von Thun, *Miteinander reden 1: Störungen und Klärungen*. Reinbek: Rowohlt, 1981.
- [4] A. C. Edmondson, „Psychological Safety and Learning Behavior in Work Teams“, *Administrative Science Quarterly*, Bd. 44, Nr. 2, S. 350–383, 1999, doi: [10.2307/2666999](https://doi.org/10.2307/2666999).
- [5] P. M. Senge, *The Fifth Discipline: The Art and Practice of the Learning Organization*. New York: Doubleday, 1990.